

HOW WE LOOK AFTER YOUR DATA.

A summary of how Cyletowns is built, hosted and secured, and how personal information is handled — written to answer the questions procurement teams ask, without the boilerplate.

THE ORGANISATION

Sport2040 · ABN 73 680 648 855
Level 15, 461 Bourke Street, Melbourne VIC 3000,
Australia

Operating **cycletowns.com**, a cycle-tourism
discovery platform.

Contact for privacy and security:
hello@cycletowns.com

We are a small Australian company and we say so plainly
rather than implying a larger security function than we have.
What follows is what is actually in place today.

HOW IT'S BUILT

Hosting	Netlify (global CDN, TLS everywhere)
Database & auth	Supabase (managed PostgreSQL)
Payments	Stripe
Email	Resend
Mapping	OpenStreetMap · OpenRouteService

Established providers running their own certified infrastructure. We operate no servers ourselves.

ACCESS & AUTHENTICATION

- **No passwords are stored.** Sign-in is by one-time email link or Google OAuth, so there is no password database to breach.
- **Row-level security** is enforced in the database on every table holding personal data — a rider can only read and write their own records, enforced by the database itself rather than by application code.
- **Administrative rights** are held in a protected field that users cannot alter, guarded by a database trigger.

- **Secrets** are held in the hosting platform's encrypted environment store, scoped to server-side execution only, and never committed to source control.
- **TLS** on every connection, with HSTS enabled.
- **Least privilege:** the key that can bypass access rules is used by exactly one server-side function (the payment webhook) and is never available to the browser.

PAYMENT DATA

Card details never reach our systems. Payments are processed entirely by Stripe, a PCI-DSS Level 1 certified provider. We hold only a Stripe customer reference and the status of a subscription. We cannot see, store or export a card number — and neither can anyone who compromised us.

DATA WE HOLD

- Email address (required — it is how people sign in)
- Optional profile: display name, home town, country, riding type, ability, short bio, photo
- Contributions: reviews, ratings, posts, saved towns, trip plans, routes
- Membership status and a Stripe customer reference

No tracking or advertising cookies. No analytics profiling. No sale of personal information, ever.

WHERE IT LIVES

Data is held with our providers, which operate infrastructure in Australia, the United States and the European Union. This is disclosed in our privacy policy, as Australian Privacy Principle 8 requires.

Partner data — your listing, your contact details, your published offers — is yours. It is exportable on request and deleted on request.

CONTINUITY, PRIVACY AND THE HONEST GAPS.

BACKUPS & RECOVERY

- **Daily** automated database backups, retained 7 days, held by our database provider
- **Weekly** independent backup to storage we control, retained 90 days — so a failure of the provider is not a failure of the backups
- Every backup is **verified as restorable** at the point it is taken
- Deployments are versioned; any previous version of the site can be republished in under a minute

MONITORING & RESPONSE

- Automated availability checks every five minutes against a health endpoint that verifies the database, payments and mapping services independently
- Application error tracking with alerting
- Faults alert a named person by email and SMS
- A documented operations runbook covers restore, rollback and incident response

PRIVACY COMPLIANCE

OBLIGATION	HOW WE MEET IT
Published privacy policy	cycletowns.com/privacy — names every provider that touches personal data, what is public and what is not, and retention
Access & correction	Most data is editable by the person directly; any request actioned within 30 days
Deletion	Account deletion removes profile, saved towns, trip plans and routes; full removal of contributions on request
Overseas disclosure	Disclosed in the privacy policy (APP 8)
Marketing consent	Separate opt-in; every marketing email carries working unsubscribe and sender identification (Spam Act 2003)
Breach notification	Affected individuals and the OAIC notified as the Notifiable Data Breaches scheme requires
Children	Not intended for under-16s; accounts removed if identified

EDITORIAL INTEGRITY

Relevant to any publicly funded partner: **paid placement is always labelled as paid**, and payment does not affect a ranking or a rider rating. Rankings come from rider ratings and published editorial criteria. We do not publish invented reviews, invented statistics or fabricated bylines.

We remove fake, abusive or competitor-written reviews — not merely unflattering ones.

WHAT WE DON'T HAVE YET

Stated plainly, because you will ask and we would rather you heard it from us:

- No third-party penetration test has been commissioned. We use automated dependency and configuration scanning.
- No ISO 27001 or SOC 2 certification.
- No 24/7 staffed operations desk — monitoring is automated and alerts a person.
- We are a small team. Continuity depends on documentation and shared credential custody, both of which are in place.

Where a contract requires an independent test or a specific certification, tell us early and we will scope it.

CONTACT

Privacy requests, security questions and disclosure of a suspected vulnerability: **hello@cycletowns.com**. We respond to security reports within two business days and will not pursue anyone reporting a genuine issue in good faith.